

Authenticatiebeleid

1. Authenticeren

1.1 Inleiding Een belangrijke beveiligingsmaatregel is om te toetsen in hoeverre TechCorp vertrouwt wie een gebruiker claimt te zijn. Dit heet authenticeren en kan op verschillende manieren plaatsvinden.

1.1.1 Expliciet uitgesloten van het beleid Sommige oudere systemen kunnen technisch niet aan dit beleid voldoen. In dat geval moet een risicoanalyse worden verricht, moeten de risico's worden geregistreerd en periodiek geëvalueerd. Aanvullend moeten compenserende controls worden ingesteld voor de uitzonderingstermijn conform uitzonderingsproces. Een uitzondering is bovendien maximaal 1 jaar geldig. Ook moeten dergelijke oudere systemen binnen een jaar worden vervangen, tenzij er een nieuw uitzonderingsverzoek is goedgekeurd. Het gebruik van XYZ certificaten is beschreven in de certificatenprocedure en geen onderdeel van dit beleid. Deze clientcertificaten zijn nodig voor de communicatie tussen D&A en XYZ voor het uitwisselen van berichten en bestanden.

1.1.2 Reden voor het beleid Overeenkomstig punt 6.4.2 van het informatiebeveiligingsbeleid moet er een IAM en dus ook een authenticatiebeleid zijn. Het beleid zorgt voor een veilig (gebruik van) authenticatiefactoren, zoals wachtwoorden en sleutels. Dit beleid is één van de onderdelen van het complete Identity & Access management beleid. Het complete beleid bestaat uit drie onderdelen:

1. Identificeren en toegangsbeheersing
2. Authenticeren
3. Autoriseren

1.1.3 Reikwijdte van het beleid Dit document bevat het beleid van TechCorp voor authenticatie, waaronder dus ook wachtwoorden en OTP's. Dit beleid is van toepassing op: alle medewerkers van TechCorp, medewerkers van andere bedrijven die door TechCorp worden ingehuurd, medewerkers van partners die computergegevens van TechCorp verwerken op TechCorp ter beschikking gestelde werkplekken, klanten van TechCorp. Medewerkers mogen op een eigen werkplek alleen werken binnen de TechCorp online omgeving, zodat lokale opslag van vertrouwelijke informatie wordt vermeden. Het is niet toegestaan om je eigen apparaat te gebruiken en data van TechCorp op te slaan, zonder uitdrukkelijke toestemming van de ISG.

1.2 Authenticatie eisen - persoonlijke accounts Voor alle niet publieke informatie geldt dat toegang wordt verkregen middels multi factor authentication (MFA). Dit is altijd het invoeren van een combinatie van iets dat je bent (bijv. vingerafdruk), iets dat je weet (wachtwoord) of iets dat je hebt (hardware token). Gebruikers moeten vanwege interoperabiliteit altijd wel een wachtwoord instellen. De volgende mogelijkheden voor aanvullende beveiligingsverificaties zijn beschikbaar:

- Waarschuwing via app
- Bellen voor extra authenticatie
- Sms met code verzenden naar telefoon
- Verificatie code uit app of hardware token (FIDO2 geschikt) gebruiken

Bij het gebruik van FIDO2 hardware tokens (iets dat je hebt) is een pincode (iets dat je weet) voldoende. Dat betekent dat je bijv. op een werkplek zonder wachtwoord moet kunnen inloggen i.c.m. een hardware token die voorzien is van een pincode (of lokaal te gebruiken wachtwoord). Voor reguliere gebruikeraccounts en privileged (beheer) accounts kunnen de mogelijkheden in Tabel 1 worden gebruikt om te authenticeren met een vast wachtwoord.

Tabel 1 Authenticatieopties bij wachtwoorden

Eis	Waarde (gebruikersaccount)	Waarde (privileged account)
Wachtwoord Lengte	Minimaal 12 karakters	Minimaal 20 karakters
Wachtwoordhistorie	6 laatste wachtwoorden worden niet gebruikt	6 laatste wachtwoorden worden niet gebruikt
Complexiteitseis	Ja	Ja
Herhalende tekens toegestaan (bijv. 'aaaaaa', '1234' of 'qwerty')	Nee	Nee
Woorden uit verboden woordenlijst blokkeren (banned passwordlist controle)	Ja	Ja
Lockout	Na 5 foutieve pogingen	Na 5 foutieve pogingen
Lockout periode	15 minuten	15 minuten
Wachtwoordleeftijd	Minimaal 1 dag, maximaal 1 jaar	Minimaal 1 dag, maximaal 1 jaar
Schermd lock	Na 15 minuten inactiviteit	Na 15 minuten inactiviteit
Extra verificatie	Risk based op basis van verdachte inlogactiviteiten	1 dag
Geldigheid (unmanaged device)	1 dag niet toegestaan op unmanaged device	
Pincode (mobiel & FIDO2) Aantal tekens	Minimaal 6 tekens	Minimaal 6 tekens

1.3 Authenticatie eisen – onpersoonlijke accounts Voor systeem-, service-, en applicatie accounts zijn afwijkende eisen opgenomen om de verstoringen van de processen zoveel mogelijk te voorkomen. Dergelijke accounts mogen niet gebruikt worden door medewerkers zelf, maar zijn puur nodig voor de werking van het systeem. De volgende eisen worden gesteld aan dit type accounts:

- Wachtwoord lengte: Minimaal 20 karakters
- Geen hergebruik van wachtwoorden
- Secrets worden willekeurig gegenereerd middels een sterk algoritme al dan niet in de vorm van een hash
- Lock-out niet actief (dit i.v.m. met mogelijke verstoring van de processen)
- Systeem Eigenaar van het account wordt vastgelegd om inzichtelijk te hebben wie moet worden benaderd bij incidenten

- De levensduur van een secret is maximaal 1 jaar en moet dan ook binnen deze termijn zijn aangepast

1.4 Authenticatie klanten – gebruik inlogmiddelen In geval van het aanbieden van digitale dienstverlening aan klanten bepaalt het betrouwbaarheidsniveau van de TechCorp dienst de wijze waarop de klant zich authentiseert om gebruik te kunnen maken van deze dienst. Voor elk(e) online product/dienst worden de eisen voor het gebruik van authenticatie middelen vastgesteld door de eigenaar van het product. Hieruit volgt of een online dienst gebruik moet maken van authenticatiemiddelen als DigiD, EHerkenning en/of eIDAS. Mocht dit niet mogelijk zijn dan moet worden voldaan aan de vereisten per betrouwbaarheidsniveau.

1.5 Uitgifte wachtwoorden gebruikers en leveranciers Het toewijzen van geheime authenticatie-informatie behoort te worden beheerst via onderstaande regels:

- Als er geen zekerheid bestaat over de geheimhouding van een wachtwoord, moet het wachtwoord onmiddellijk worden gewijzigd door de medewerker.
- Wachtwoorden deel je niet met anderen.
- Schriftelijke vastlegging van wachtwoorden is niet toegestaan. Digitale vastlegging alleen met wachtwoordmanager.
- Initiële wachtwoorden moeten binnen twee dagen gewijzigd worden, is het wachtwoord niet gewijzigd, dan wordt het account geblokkeerd.
- Wachtwoorden worden op een veilige wijze uitgegeven met de controle van de identiteit conform de procedure voor uitgifte van wachtwoorden.

1.6 Authenticatie leveranciers Leveranciers kunnen alleen toegang krijgen tot TechCorp producten en -diensten via het leverancierskanaal onder strikte voorwaarden. Het vereiste authenticatiemiddel op het leverancierskanaal vanaf het leveranciersdomein is multi-factor-authenticatie. In geval van uitbestedingen is de contracthouder aan de leverancier zijde verantwoordelijk het aansluiten op het leverancier kanaal en voor de authenticatie van zijn/haar medewerkers. De contracthouder van TechCorp ziet toe op de naleving van deze eisen door de leverancier tijdens de periodieke performance gesprekken met de leverancier, zoals is opgenomen de procesbeschrijving INK-02 Contractbeheer en -management TechCorp. In de evaluatie van de leverancier worden verbeterpunten gemonitord en significante risico's door de contracteigenaar besproken en beheerst. De contractopsteller van TechCorp is verantwoordelijk voor het opnemen van alle informatiebeveiligings-eisen uit deze beleidsstandaard in het contract met de leverancier.

1.7 Opslag van inloggegevens

1.7.1 Beleidsuitgangspunten Inloggegevens (o.a. wachtwoorden, tokens en keys) van onpersoonlijke en privileged accounts worden opgeslagen in een wachtwoordkluis die in het beheer is van TechCorp Tech & Change. De wachtwoorden van systeem- en service accounts worden niet in leesbare vorm in de broncode opgenomen door het gebruik van bijvoorbeeld Azure Keyvault. Daardoor wordt het roteren van wachtwoorden ook makkelijker mogelijk. Het voorkomen van wachtwoorden die in broncode wordt opgeslagen wordt middels Statische Code Analyse standaard gecontroleerd. Uitzonderingen moeten worden aangemeld in het risicoregister van het betreffende directie of afdeling.

1.7.2 Gebruik wachtwoord kluis Gebruik een online of offline wachtwoordmanager voor je eigen account. Een wachtwoordmanager is de manier om wachtwoorden digitaal te beheren. De wachtwoorden dienen versleuteld opgeslagen te worden, en kunnen gesynchroniseerd worden tussen werkcomputer en mobiele telefoon. Om toegang te krijgen tot de wachtwoordmanager hoe de medewerker slechts één sterk hoofdwachtwoord te onthouden. Beperk het aantal wachtwoorden door gebruik te maken van de Single Sign On (SSO) voorziening binnen TechCorp. Alle wachtwoorden worden opgeslagen in de wachtwoordmanager.

1.8 Gebruik accounts met kritieke toegang De regels voor het gebruik van privileged accounts zijn:

- Medewerkers, waaronder beheerders hebben standaard geen toegang tot de wachtwoorden van accounts met kritieke rechten.
- Een door een beheerder aangemaakt kritiek account authenticiseert vooraf alleen met multi factor authenticatie.
- Voor gebruik van accounts met kritieke toegang moet altijd herleidbaar zijn wie, wanneer, waarom en hoe lang de toegang nodig is en wordt dit altijd gelogd conform de eisen uit het logbeleid van TechCorp.
- Opslag van wachtwoorden is alleen versleuteld toegestaan in de goedgekeurde oplossing voor privileged accounts door het ISG.
- De wachtwoorden worden minimaal elk kwartaal gewijzigd en na gebruik.
- Voor Azure wordt altijd Azure PIM gebruikt en hebben beheerders niet direct toegang buiten het PIM portaal. Daardoor kunnen dergelijke inloggegevens niet lekken en is er altijd gecontroleerd toegang met de benodigde logging bij gebruik om misbruik te kunnen detecteren.
- Een door het systeem aangemaakt kritiek account is voorzien van een wachtwoord met minimaal twintig posities en dient uit alle karakters te bestaan.
- De processen voor het aanmaken, wijzigen, verwijderen en periodiek controleren van kritieke accounts zijn beschreven en voldoen aan het logbeleid van TechCorp.

1.9 Noodherstelaccounts Bij het aanmaken van noodherstelaccounts (ook wel breaking glass accounts genoemd) dient altijd advies gevraagd te worden aan de ISG. In de basis worden noodherstel accounts nooit gebruikt, tenzij zich er een crisisscenario voordoet. De volgende eisen gelden bij het registreren van een noodherstelaccount:

- Bij elk noodherstelaccount hoort een eigenaar te zijn gekoppeld
- Goedkeuring van de systeem / applicatie-eigenaar
- Het wachtwoord voldoet aan de complexiteitseisen van een privileged account, met uitzondering dat de levensduur van een wachtwoord niet gebonden is aan een termijn.
- Het wachtwoord kan gezien worden op een eenmalig te gebruiken wachtwoord (One-Time-Password OTP).
- Het wachtwoord wordt na elk gebruik gewijzigd en is niet zichtbaar voor de beheerder.
- Er is altijd een register aanwezig bij gebruik van het account.
- Er is een goedkeuringsprocedure voor gebruik en wijzigen van een inloggegevens. Goedkeuring vindt plaats door de eigenaar van de dienst.

Referenties en definities

- Secret: Alle vertrouwelijke authenticatie informatie behorende bij een account (bijv. wachtwoorden, keys of tokens)
 - Systeem: Geautomatiseerd object dat als basis dient voor bijvoorbeeld een applicatie of database. (Bijvoorbeeld Azure Active Directory)
-